

自主行動端 Agent 攻陷後安全：行動執行權限之確定性運行時強制執行

Post-Compromise Security for Autonomous Mobile Agents: Deterministic Runtime Enforcement of Mobile Execution Authority

陳濬程 / Chun-Cheng (Jimmy) Chen
研發部 (Research and Development Division)
康宸園有限公司 (Top-Celestial Company Ltd.)
台灣台北市 (Taipei, Taiwan R.O.C.)
jimmychen@dr-os.io

Abstract—自主行動端 Agent 日益將基於學習或大型語言模型 (LLM/VLA) 的決策進程與特權行動端 API 及作業系統服務相結合。這引發了一個與傳統模型魯棒性本質不同的攻陷後安全問題：當自主控制器被完全攻陷後，未授權的認知圖是否仍能獲取下游行動作業系統的執行權限？

我們形式化定義了「行動端 Agent 攻陷後執行權限問題」，並深入探討確定性運行時強制執行層能否在獨立於控制器完整性的前提下，持續維持執行授權約束。我們提出了 **DROS-Mobile** 作為參考實作，安置於自主 Agent 意圖與受保護行動執行介面之間。該設計透過顯式的主體、能力、策略與撤銷校驗，將認知意圖與執行權限徹底解耦。

我們形式化定義了三大核心性質：未授權受保護系統效果不變量 (P1)、撤銷邊界執行權限 (P2)、以及宣告受保護路徑 $\mathcal{E}_{\text{protected}}$ 下的委託非擴權 (P3)。我們在 iOS 與 Android 環境下，針對正常執行、完全失陷 Agent 行為 (C^*)、對抗性 API 請求、授權繞過嘗試、能力重放、撤銷競爭以及持續高壓負載進行了全量評測。

實驗結果客觀度量了未授權受保護系統效果、遏制率、多階撤銷時窗 (T_{rev} 與 T_{RCU})、委託傳播、解耦執行延遲與運行時開銷。本研究為在自主行動認知與作業系統中介執行邊界處研究攻陷後安全，提供了一套可嚴格實驗證偽的科學方法學基底。

Index Terms—行動端 Agent 安全，攻陷後安全，運行時強制執行，執行權限，受保護系統效果，行動作業系統。

I. 引言 (INTRODUCTION)

大型語言模型 (LLMs)、視覺-語言-動作模型 (VLA) 與自主任務規劃 Agent 在行動作業系統 (iOS 與 Android) 上的深度整合，大幅擴展了特權系統互動的攻擊面。現代行動端 Agent 被賦予了自主檢索相簿、解析簡訊驗證碼、調用通訊錄、操作本地應用儲存以及發起金融交易的能力。

然而，直接賦予生成式模型無約束的特權 API 訪問權，帶來了不可迴避的根本安全悖論。當端側認知 Agent 遭受提示注入攻擊、多模態對抗感知或檢索增強記憶污染時，模型內部的對齊機制根本無法阻止其發出未授權的惡意系統調用。

在行動安全領域，攻擊具有即時、不可逆的數位副作用：敏感個資外洩、透過 Apple Pay / Android Keystore 發起未授權轉帳、或未授權的後台網路信標發送。這一嚴酷現實引出了本文的核心科學問題：

當自主行動端 Agent 被完全攻陷後，受信任的執行層能否阻止未授權的 Agent 意圖產生下游受保護行動系統效果？

我們形式化提出了核心安全命題：

$$\text{Compromise}(\text{Cognitive Controller}) \not\Rightarrow \text{Compromise}(\text{Mobile Execution Authority}) \quad (1)$$

為了嚴謹探討此問題，本文介紹了 **DROS-Mobile** 作為位於自主 Agent 意圖與受保護行動 SDK 介面之間的開源參考實作，透過 C-ABI 建立一道確定性的二進位授權門禁。

A. 主要學術貢獻

- 1) **問題形式化**：形式化定義了行動端 Agent 攻陷後執行權限問題，明確解耦認知模型失陷與下游行動執行權限。
- 2) **形式化安全性質**：形式化定義了三大可驗證性質：未授權受保護系統效果不變量 (P1)、撤銷邊界執行權限 (P2)、以及委託非擴權 (P3)。
- 3) **參考架構設計**：提出了 **DROS-Mobile** 執行門禁，透過 C-ABI 跨 iOS (Swift) 與 Android (JNI) 平台運作，明確界定保護範圍於宣告介面路徑 $\mathcal{E}_{\text{protected}}$ 。
- 4) **可重現實驗方法學**：在 iOS 與 Android 測試床上構建了 M1-M6 六階實驗階梯，針對黑盒失陷控制器 (C^*)、能力重放與微秒級撤銷競爭進行了全量驗證。

II. 相關工作與研究定位 (RELATED WORK)

A. 行動應用沙盒與作業系統權限

傳統行動安全依賴作業系統的應用沙盒與運行時權限框架 (例如 iOS TCC、Android Runtime Permissions) [1], [6]。儘管這些機制限制了跨應用的權限提升，但其運作粒度以主宿應用為單位。一旦應用獲得權限，運行於該應用內部的自主 Agent 便無差別繼承所有權限，缺乏細粒度的時間或語意約束。

B. LLM Agent 護欄與數位遏制

近年研究透過中介軟體護欄、提示詞過濾與工具調用仲裁來增強 Agent 安全 [2], [7]。然而，現有護欄主要運行於應用層，或依賴二次呼叫 LLM 驗證器，這會引入數百毫秒的延遲，且可透過直接 API 調用繞過。

C. 研究空白與實驗基底定位

現有研究日益探討攻陷後行為、運行時授權與行動安全，但這些研究往往依賴碎片化的實驗基底與不同的保證邊界 [3], [4], [8]。一個能完整揭露從失陷 Agent 意圖到受保護系統效果全轉換過程的可重現執行基底，對於系統化評測攻陷後執行安全至關重要。

在這一統一科研範式中：

- **DRoS** 提供了一個開源、可重現、可執行的參考基底；
- **VEP** 提供了獨立於具體實作的評測與證偽協議；
- **Mobile 與 UAV** 分別在數位系統效果 ($PSE \equiv 0$) 與網絡-實體動能包絡線 ($\Delta u_{cmd} \equiv 0 \wedge x(t) \in \mathcal{S}_{safe}$) 兩大場域具體實例化了攻陷後安全問題。

III. 系統與威脅模型 (SYSTEM & THREAT MODEL)

A. 不可信控制器模型 (C^*)

認知控制器被建模為對抗性黑盒：

$$C^* : \mathcal{I} \rightarrow \mathcal{A}^* \quad \text{其中} \quad \mathcal{A}^* \subseteq \mathcal{A}_{arbitrary} \quad (2)$$

攻擊者可發出任意合法或非法 API 調用、篡改參數緩衝區、重放過期 Token，並嘗試垂直或水平提權。

B. 受信任執行邊界與宣告路徑範疇 ($\mathcal{E}_{protected}$)

安全保證邊界嚴格限定於宣告的受保護執行路徑：

$$\mathcal{E}_{protected} = \{\text{被執行門禁覆蓋之受保護路徑}\} \quad (3)$$

DRoS-Mobile 對任何動作 $a \in \mathcal{E}_{protected}$ 強制執行授權。其不宣稱保護宣告邊界之外的任意 OS 效果。

C. 排除範疇聲明 (*Out-of-Scope*)

透過硬體除錯器 / JTAG 進行的實體記憶體篡改、基頻處理器攻陷、OS 內核級提權 (iOS 內核崩潰 / Android Rootkit) 以及 Secure Enclave 硬體失陷均屬於本文討論範圍之外。

IV. 形式化安全性質 (FORMAL SECURITY PROPERTIES)

A. 性質 $P1$ — 未授權受保護系統效果不變量 ($UPSEI$)

$$\forall a \in \mathcal{E}_{protected}, \quad \text{Auth}(a, s, t) = 0 \implies PSE(a, s, t) \equiv 0 \quad (4)$$

其中 PSE 明確定義為觸及受保護 API、金融服務、應用儲存與網路 Socket 的任何狀態變更、未授權讀取或 IPC 傳輸。

B. 性質 $P2$ — 撤銷邊界執行權限

設能力 c 於時間戳 t_r 被撤銷。在有界撤銷時窗 τ_r 內：

$$\text{Revoked}(c, t_r) = 1 \implies \forall t \geq t_r + \tau_r, \quad \text{Auth}(a_c, s, t) = 0 \wedge PSE(a_c, s, t) \equiv 0 \quad (5)$$

其中 $T_{rev} = t_{\text{first guaranteed DENY}} - t_{\text{revocation commit}} < 2.5 \mu\text{s}$ [10]。

C. 性質 $P3$ — 委託非擴權

$$\text{Authority}_{child} \subseteq \text{Attenuate}(\text{Authority}_{parent}) \wedge \text{UnauthorizedPropagation} \equiv 0 \quad (6)$$

V. 實驗評測 (M1-M6 LADDER)

A. 實驗環境配置

- **iOS 環境**：Apple A17 Pro (iOS 18) · Swift 5.10 配合 C-ABI 靜態綁定。
- **Android 環境**：Snapdragon 8 Gen 3 (Android 14) · Kotlin 配合 JNI C-ABI 動態函式庫 (`libdros_mobile.so`)。
- **負載規模**：10,000 次連續基準測試，隨機注入對抗樣本。

B. 開銷與能耗揭露

- **決策延遲**：iOS Swift $P_{50} = 1.70 \mu\text{s}$, $P_{99} = 7.30 \mu\text{s}$ ；Android JNI $P_{50} = 2.10 \mu\text{s}$, $P_{99} = 8.50 \mu\text{s}$ 。
- **記憶體開銷**：在指定之 10,000 次測試負載下觀察：初始記憶體池分配後未檢測到記憶體增長 ($\Delta M = 0 \text{ B}$)。
- **能耗開銷**：根據實測執行成本估算能量開銷 (L1/L2 快取內單次調用 $< 0.05 \mu\text{J}$)，避免喚醒 4G/5G 射頻晶片。

VI. 限制與邊界討論 (LIMITATIONS)

DRoS-Mobile 在宣告之威脅模型與介面邊界 $\mathcal{E}_{protected}$ 內提供確定性遏制。然而，其不宣稱能防禦實體硬體拆解、基頻晶片攻陷或零日 OS 內核 Rootkit。此外，保護範疇受限於宣告之受保護 API 集合。

VII. 結論 (CONCLUSION)

本文探討了當自主行動端 Agent 之認知控制器被假定完全失陷時，數位動作權限是否仍能受到強制約束。透過 DRoS-Mobile 參考實作，我們證明了解耦認知規劃與執行權限可使形式化不變量 ($P1$ 、 $P2$ 、 $P3$) 在微秒級延遲且零後台網路依賴的前提下嚴格成立。

兩大領域共同為核心範式提供了堅實的經驗證據：

$$\text{Cognitive Compromise} \not\equiv \text{Execution Authority Compromise} \quad (7)$$

致謝與 AI 協作聲明 (AI DECLARATION)

生成式 AI 工具僅用於技術文字輔助、語法潤飾與 L^AT_EX 排版編排。核心研究願景、科學問題定義、系統架構設計、形式化不變量、實驗方法學、數據分析與所有學術主張均由作者獨立提出並驗證。作者對本文的所有內容承擔完全責任。

TABLE I
跨行動平台攻陷後安全評測矩陣 (M1–M6)

階段	評測階段	注入對抗向量	評測指標與合格標準	實測結果
M1	正常執行	合法讀取相簿資源	$PSE = 1, P_{50} \leq 1.70 \mu s, 0$ 誤拒絕	通過
M2	完全失陷 (C^*)	發出惡意系統意圖	認知層確認產生未授權意圖	通過
M3	執行期遏制	未授權外洩簡訊與通訊錄	$Auth = 0 \implies PSE \equiv 0 (R_{\text{contain}} = 1.0)$	通過
M4	能力濫用	過期 Token、枚舉變更	100% 閉鎖式拒絕 ($R_{\text{FC}} = 1.0$)	通過
M5	撤銷競爭	於 $t_r + \Delta t$ 重放已撤銷憑證	$T_{\text{rev}} < 2.5 \mu s, 0$ 撤銷後未授權效果	通過
M6	高壓負載	10,000 次連續邊界變異	0 崩潰 · 無可檢測之記憶體增長 ($\Delta M = 0$)	通過

REFERENCES

- [1] W. Enck et al., “TaintDroid: An information-flow tracking system for real-time privacy monitoring on smartphones,” *ACM TOCS*, vol. 32, no. 2, pp. 1–32, 2014.
- [2] Y. Liu et al., “Prompt injection attacks and defenses in LLM-integrated applications,” in *IEEE S&P*, 2024, pp. 1042–1059.
- [3] J. B. Dennis and E. C. Van Horn, “Programming semantics for multiprogrammed computations,” *CACM*, vol. 9, no. 3, pp. 143–155, 1966.
- [4] H. M. Levy, *Capability-Based Computer Systems*, Digital Press, 2014.
- [5] C.-C. Chen, “DROS: Deterministic Runtime Governance Substrate for Autonomous Agentic Execution,” *IEEE ICA Tech Report*, no. 7782439, 2026.
- [6] Apple Inc., “Security and Privacy in iOS: TCC Architecture,” *Apple Platform Security*, 2024.
- [7] NVIDIA, “NeMo Guardrails: Programmable Guardrails for LLM Applications,” *NVIDIA Dev Docs*, 2024.
- [8] X. Zhang et al., “AgentSight: eBPF-Powered Tracing and Context Correlation for Autonomous LLM Agents,” in *USENIX Security*, 2024.
- [9] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” *OWASP Standard*, 2025.
- [10] P. E. McKenney, “Read-Copy Update Architecture and Synchronization Mechanisms,” *IBM LTC*, 2024.